
— SPÉCIMEN · RAPPORT D'EXEMPLE

Rapport de test d'intrusion

Application web & API REST : évaluation en
boîte grise authentifiée

CLIENT

OWASP Juice Shop

Boutique e-commerce & API REST · juice-shop.example

RÉFÉRENCE

B16-2026-0142

DATE DU RAPPORT

8 juillet 2026

TYPE DE TEST

Boîte grise, authentifié

MÉTHODOLOGIE

OWASP WSTG · API Top 10

base16

Test d'intrusion & audit de sécurité

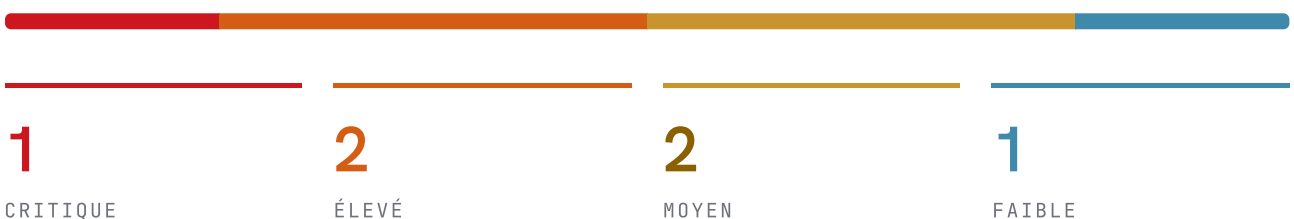
base16.fr

contact@base16.fr

01 · SYNTHÈSE EXÉCUTIVE

Six vulnérabilités, dont **une critique** exploitable sans privilège.

Sept jours de test manuel en boîte grise ont révélé des défauts de contrôle d'accès et de logique métier : un utilisateur authentifié peut lire les données d'autres clients et déclencher des remboursements non autorisés.



VERDICT

L'isolation entre comptes clients est insuffisante. La faille critique **F-01** laisse n'importe quel compte lire les factures des autres en changeant un identifiant dans l'URL. Bloquant pour une revue SOC 2 ou un contrôle client.

RECOMMANDATION PRIORITAIRE

Corriger d'abord **F-01, F-02 et F-03**. Cause commune : l'autorisation est vérifiée au niveau de la route, jamais au niveau de l'objet. Un contrôle d'accès centralisé côté serveur ferme les trois.

Contexte. Test de l'application web et de son API REST, en accès authentifié avec deux comptes clients. Objectif : mesurer ce qu'un utilisateur légitime peut atteindre au-delà de son périmètre. Tests manuels (OWASP WSTG, API Top 10), sans action destructive, sur l'environnement de recette convenu.

02 · PÉRIMÈTRE & MÉTHODOLOGIE

Ce qui a été testé, et comment.

CIBLE APPLICATIVE

app.juice-shop.example

TYPE DE TEST

Boîte grise, authentifié · 2 comptes

MÉTHODOLOGIE

OWASP WSTG v4.2 · API Top 10 (2023)

ENVIRONNEMENT

Recette · données synthétiques

CIBLE API

api.juice-shop.example/v1

FENÊTRE DE TEST

7 jours ouverts · juin 2026

NOTATION

CVSS v3.1

HORS PÉRIMÈTRE

Infra réseau, e-mails, déni de service

03 · REGISTRE DES VULNÉRABILITÉS

RÉF.	VULNÉRABILITÉ	SÉVÉRITÉ	CVSS	STATUT
F-01	Accès aux factures d'autres clients (BOLA) GET /api/v1/invoices/{id}	■ CRITIQUE	9.1	Ouvert
F-02	Rejeu d'une requête de remboursement POST /api/v1/refund	■ ÉLEVÉ	8.2	Ouvert
F-03	Élévation de privilège par mass assignment PATCH /api/v1/users/me	■ ÉLEVÉ	8.1	Ouvert
F-04	XSS stocké dans le nom d'un widget Dashboard · champ « title »	■ MOYEN	6.4	Ouvert
F-05	Jetons JWT sans révocation, expiration 30 j Authentification · session	■ MOYEN	5.9	Ouvert
F-06	Absence de limitation de débit sur la connexion POST /api/v1/login	■ FAIBLE	3.7	Ouvert

La sévérité combine l'impact technique (CVSS v3.1) et le contexte métier observé. Les

04 · CONSTATS DÉTAILLÉS

F-01

Accès aux factures d'autres clients (BOLA / IDOR)

9.1

CRITIQUE · CVSS 3.1

ENDPOINT

GET /api/v1/invoices/{id}

CATÉGORIE

API1:2023 · BOLA

DESCRIPTION

L'endpoint autorise l'accès sur la **seule base de la session authentifiée**, sans vérifier que la facture appartient à l'appelant. L'identifiant {id} étant séquentiel, il suffit de l'incrémenter pour lire les factures de tous les autres clients.

PREUVE D'EXPLOITATION

```
# Bob (compte standard) lit sa facture : id 3041.
$ curl -s .../v1/invoices/3041 -H "Authorization: Bearer <bob>"
200 OK {"id":3041,"user":"bob","total":"1 290.00" ...}
# Même jeton, on décrémente l'id → facture d'un autre client.
$ curl -s .../v1/invoices/3040 -H "Authorization: Bearer <bob>"
200 OK {"id":3040,"user":"alice@northwind.io","total":"14 500.00" ...}
# → fuite inter-comptes confirmée · 3 000+ factures énumérables.
```

IMPACT

Un seul compte suffit à extraire **toute la base de factures** : coordonnées, montants, historique d'achat. Fuite de données personnelles, exposition RGPD. Portée **modifiée (S:C)** : la faille franchit l'isolation entre comptes.

RECOMMANDATION

Vérifier la propriété de l'objet à chaque requête, côté serveur.

- Filtrer par le compte de la session : **WHERE invoice.user_id = session.user_id** ; ne jamais se fier à l'id seul.
- Remplacer les identifiants séquentiels par des **UUID non devinables** (défense en profondeur).
- Centraliser l'autorisation objet dans un middleware unique.

Références : OWASP API1:2023 (BOLA) · WSTG-ATHZ-04 · CWE-639

04 · CONSTATS DÉTAILLÉS (SUITE)

F-02

Rejeu d'une requête de remboursement

8.2

ÉLEVÉ · CVSS 3.1

ENDPOINT

POST /api/v1/refund

CATÉGORIE

Logique métier · WSTG-BUSL-03

DESCRIPTION

La requête de remboursement n'a **ni jeton d'idempotence ni contrôle d'unicité**. La même requête signée peut être renvoyée indéfiniment : chaque rejeu recrédite le compte. Le serveur ne détecte pas qu'un remboursement a déjà été émis pour la transaction.

PREUVE D'EXPLOITATION

```
# Un remboursement de 50,00 € est capturé, puis rejoué 3x.
$ for i in 1 2 3; do
  curl -s -X POST https://api.juice-shop.example/v1/refund \
    -H "Authorization: Bearer <jeton>" \
    -d '{"tx":"TX-88213","amount":"50.00"}'; done
200 {"refund":"RF-1","status":"credited"}
200 {"refund":"RF-2","status":"credited"} # doublon accepté
200 {"refund":"RF-3","status":"credited"} # → 150 € pour 50 € dus
```

IMPACT

Fraude financière directe : un client se crédite de façon répétée à partir d'une seule transaction réelle. Automatisée, la perte est **non bornée** et passe inaperçue dans les journaux, chaque rejeu ressemblant à une opération valide.

RECOMMANDATION

Rendre l'opération idempotente et unique par transaction.

- Exiger une **clé d'idempotence** (Idempotency-Key) et rejeter tout rejeu de la même clé.
- Poser une **contrainte d'unicité** en base : au plus un remboursement par tx, en transaction atomique.
- Vérifier que le montant remboursé ne dépasse jamais le montant réglé d'origine.

Références : OWASP WSTG-BUSL-03 · API6:2023 · CWE-837

04 · CONSTATS DÉTAILLÉS (SUITE)

F-03

Élévation de privilège par mass assignment

8.1

ÉLEVÉ · CVSS 3.1

ENDPOINT

PATCH /api/v1/users/me

CATÉGORIE

API3:2023 · BOPLA

DESCRIPTION

La mise à jour du profil lie directement le corps JSON au modèle utilisateur. Le champ **role**, censé être en lecture seule, est accepté s'il est présent. Un utilisateur standard se promeut **administrateur** en une requête.

PREUVE D'EXPLOITATION

```
# Bob est "member". Il ajoute un champ role non prévu par l'UI.
$ curl -s -X PATCH https://api.juice-shop.example/v1/users/me \
  -H "Authorization: Bearer <jeton_bob>" \
  -d '{"name":"Bob","role":"admin"}'
200 OK {"id":812,"name":"Bob","role":"admin"}
# → accès gestion des membres, facturation, export org.
```

IMPACT

Prise de contrôle du back-office par un compte standard : gestion des utilisateurs, paramètres de paiement, export des données. Combinée à **F-01**, la portée dépasse le compte de l'attaquant.

RECOMMANDATION

N'accepter en entrée que les champs explicitement autorisés.

- Utiliser une **liste blanche** de propriétés modifiables (name, email...); ignorer le reste.
- Traiter role et les attributs sensibles via un flux d'administration dédié, contrôlé côté serveur.
- Journaliser et alerter sur toute tentative de modification d'un champ protégé.

Références : OWASP API3:2023 (BOPLA) · WSTG-BUSL-01 · CWE-915

05 · DÉMARCHE SUIVIE

Quatre étapes, du cadrage au contre-test.

01

Cadrage

Périmètre, comptes de test et règles d'engagement écrites. Prix fixe validé avant tout test.

02

Test manuel

7 jours d'exploration à la main, canal direct ouvert. Critique signalé le jour de sa découverte.

03

Rapport

Chaque faille : criticité, reproduction, impact réel, correctif concret, plus cette synthèse.

04

Contre-test

Après correction : re-vérification de chaque faille et attestation à jour. Inclus, sous 30 jours.

06 · PROCHAINE ÉTAPE & ATTESTATION

**Contre-test & attestation de correction**

Une fois les vulnérabilités corrigées, chaque constat est re-testé pour confirmer sa fermeture. Une **attestation datée et signée** (périmètre, méthodologie, état final de chaque faille) est alors délivrée. C'est ce document que vous transmettez à vos clients, à un auditeur SOC 2 ou dans un dossier ISO 27001.

Ce rapport est un spécimen : OWASP Juice Shop est une application volontairement vulnérable, utilisée ici comme cible de démonstration. La structure et le format correspondent à un livrable réel base16.

base16

Test d'intrusion & audit de sécurité · web & API



Un test de cette nature pour votre application ? · base16.fr · contact@base16.fr · réponse sous 24 h